

Gouvernance et gestion des risques de la sécurité de l'information

Diapositives complètes — Dr. Zakaria Sawadogo, École Polytechnique de Ouagadougou

Chapitre 1 — Introduction à la gouvernance de la sécurité de l'information

Gouvernance et gestion des risques SI

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Définition de la gouvernance SSI

La gouvernance de la sécurité de l'information désigne l'ensemble des structures, processus et mécanismes de décision qui permettent à une organisation de définir, piloter et faire évoluer sa stratégie de sécurité, en cohérence avec ses objectifs métiers et son appétence au risque. Elle se distingue de la sécurité opérationnelle (mise en œuvre technique quotidienne) par son niveau : la gouvernance définit le « quoi » et le « pourquoi », l'opérationnel exécute le « comment ».

2. Pourquoi la sécurité doit être gouvernée et non seulement « techniquement gérée »

- La sécurité a un coût et engage des arbitrages (budget, ressources humaines, priorités) qui relèvent de décisions de direction, pas seulement d'équipes techniques.
- Un incident de sécurité majeur a des conséquences qui dépassent l'informatique (juridiques, financières, réputationnelles) : la direction doit être impliquée dans l'appétence au risque acceptée.
- Sans portage par la direction, les recommandations issues des audits (module précédent) restent rarement suivies d'effet.

3. Les rôles clés

Rôle	Responsabilité principale
Direction générale	définit l'appétence au risque, arbitre les budgets, porte la culture sécurité
RSSI (Responsable de la Sécurité des Systèmes d'Information)	pilote la stratégie SSI, anime la gouvernance, rapporte à la direction
DSI	met en œuvre les moyens techniques, souvent en tension avec le RSSI sur les priorités (disponibilité vs sécurité)
Propriétaires de processus métier (business owners)	identifient la valeur et la criticité des actifs qu'ils exploitent, arbitrent le traitement du risque sur leur périmètre
Correspondants sécurité / DPO	relais opérationnels, conformité réglementaire (protection des données)

Un point de vigilance de gouvernance fréquent : le RSSI, pour rester indépendant, ne devrait idéalement pas être rattaché hiérarchiquement à la DSI qu'il est censé challenger.

4. Les composantes d'un système de gouvernance SSI

1. **Politique de sécurité** (PSSI) : document de référence formalisant les orientations, principes et responsabilités.
2. **Organisation** : comités de pilotage, instances de décision, circuits d'escalade.
3. **Gestion des risques** : méthodologie d'identification, d'évaluation et de traitement des risques (chapitre 2).
4. **Conformité** : suivi des obligations légales, réglementaires et contractuelles.
5. **Pilotage et amélioration continue** : indicateurs, tableaux de bord, audits internes, revues de direction.

5. Cadres de référence en gouvernance SSI

- **ISO/IEC 27001** : SMSI, avec un accent fort sur le pilotage par la direction (clause 5).
- **COBIT** : cadre de gouvernance des systèmes d'information au sens large, incluant la sécurité.
- **NIST Cybersecurity Framework** : structure la gouvernance autour de cinq fonctions (Identify, Protect, Detect, Respond, Recover), largement adoptée au-delà du contexte américain.

6. Maturité et amélioration continue

La gouvernance SSI n'est pas un état figé : elle progresse par cycles (souvent modélisés en PDCA — Plan, Do, Check, Act). Une organisation immature réagit aux incidents au coup par coup ; une organisation mature anticipe par une gestion structurée des risques et ajuste ses priorités sur la base d'indicateurs et de retours d'expérience.

À retenir

- La gouvernance SSI relève de la direction, pas uniquement des équipes techniques : elle arbitre l'appétence au risque et les moyens alloués.
- Un RSSI efficace a besoin d'un positionnement organisationnel qui préserve son indépendance vis-à-vis de la DSI.
- La gouvernance s'appuie sur un cycle continu : politique, gestion des risques, conformité, pilotage, amélioration.

Chapitre 2 — Méthodologies d'analyse de risques

Gouvernance et gestion des risques SI

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Vocabulaire de base de la gestion des risques

Terme	Définition
Actif (asset)	tout élément ayant de la valeur pour l'organisation (donnée, système, processus, image)
Menace	événement potentiel pouvant porter atteinte à un actif (attaque, erreur humaine, panne, catastrophe naturelle)
Vulnérabilité	faiblesse exploitable par une menace
Risque	combinaison de la probabilité qu'une menace exploite une vulnérabilité et de l'impact qui en résulterait
Mesure de sécurité (contrôle)	action réduisant la probabilité et/ou l'impact d'un risque
Risque résiduel	risque subsistant après application des mesures de sécurité

Formule couramment utilisée pour qualifier un risque : **Risque = Probabilité × Impact** (souvent affinée par des échelles qualitatives à 3-5 niveaux plutôt qu'un calcul numérique naïf).

2. EBIOS Risk Manager (méthode ANSSI)

EBIOS RM structure l'analyse en cinq ateliers :

1. **Cadrage et socle de sécurité** : périmètre de l'étude, missions et valeurs métier, événements redoutés, socle de mesures de sécurité déjà en place.
2. **Sources de risque** : identification des sources de risque (attaquant opportuniste, concurrent, État, initié malveillant) et de leurs objectifs visés.
3. **Scénarios stratégiques** : chemins d'attaque à haut niveau, cartographie de l'écosystème (fournisseurs, partenaires comme vecteurs indirects).
4. **Scénarios opérationnels** : déroulé technique détaillé d'une attaque, mode opératoire probable.
5. **Traitement du risque** : synthèse des risques, décision de traitement, plan d'action et suivi.

EBIOS RM se distingue par son approche « par la menace » (partir des scénarios d'attaque plausibles) en complément d'une approche « par les actifs ».

3. ISO/IEC 27005

Norme internationale de référence pour la gestion des risques SSI, structurée en :

1. Établissement du contexte (critères de risque, périmètre).
2. Appréciation du risque (identification, analyse, évaluation).
3. Traitement du risque.
4. Acceptation du risque.
5. Communication et concertation.
6. Surveillance et revue.

ISO 27005 est le référentiel généralement utilisé pour nourrir le processus de gestion des risques exigé par la clause 6 de l'ISO 27001, dans une logique de certification.

4. NIST Risk Management Framework (RMF)

Cadre en sept étapes (Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor), largement utilisé dans le secteur public américain et par des organisations internationales, avec une articulation forte entre catégorisation des systèmes (impact potentiel) et sélection de mesures de sécurité issues d'un catalogue (NIST SP 800-53).

5. Comparaison synthétique

Critère	EBIOS RM	ISO 27005	NIST RMF
Origine	France (ANSSI)	International (ISO)	États-Unis (NIST)
Approche dominante	par la menace (scénarios d'attaque)	par les actifs et le contexte	par la catégorisation et un catalogue de contrôles
Usage typique	administrations, OIV, grandes entreprises francophones	certification ISO 27001	secteur public américain, sous-traitants fédéraux

Ces méthodes ne sont pas mutuellement exclusives : une organisation peut s'appuyer sur ISO 27005 pour son SMSI certifié tout en utilisant les ateliers EBIOS RM pour affiner l'analyse des scénarios d'attaque les plus critiques.

6. Échelles d'évaluation

Un exemple d'échelle qualitative simple à 4 niveaux, utilisable en TP :

Niveau	Probabilité	Impact
1	Rare	Négligeable
2	Possible	Modéré
3	Probable	Majeur
4	Quasi certain	Critique (met en péril la continuité)

La combinaison probabilité × impact positionne chaque risque sur une **matrice de criticité**, outil central de priorisation (repris en TP2).

À retenir

- Risque = fonction de la probabilité d'occurrence et de l'impact, jamais l'un sans l'autre.
- EBIOS RM structure l'analyse « par la menace » en cinq ateliers ; ISO 27005 structure l'analyse « par le contexte et les actifs » en six étapes.
- Le choix de la méthode dépend souvent du contexte réglementaire et sectoriel de l'organisation.

Chapitre 3 — Traitement du risque, PSSI et continuité d'activité

Gouvernance et gestion des risques SI

DR. ZAKARIA SAWADO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Les quatre stratégies de traitement du risque

Stratégie	Principe	Exemple
Éviter	supprimer l'activité ou l'actif générant le risque	ne pas exposer un service inutile sur Internet
Réduire (atténuer)	mettre en œuvre des mesures pour diminuer probabilité et/ou impact	déployer un pare-feu, chiffrer les données
Transférer (partager)	déplacer une partie de l'impact vers un tiers	souscrire une cyber-assurance, externaliser à un prestataire avec obligations contractuelles
Accepter	assumer consciemment le risque, en général si le coût du traitement dépasse l'impact potentiel	accepter un risque résiduel faible après mise en œuvre des mesures principales

Le choix résulte d'un arbitrage coût/bénéfice, validé par le niveau de gouvernance approprié (la direction pour les risques majeurs).

2. La Politique de Sécurité des Systèmes d'Information (PSSI)

La PSSI est le document de référence formalisant les orientations stratégiques et les règles de sécurité applicables à l'ensemble de l'organisation. Elle se décline généralement en plusieurs niveaux :

1. **Politique générale** : principes, engagement de la direction, périmètre (quelques pages, stable dans le temps).
2. **Politiques thématiques** : contrôle d'accès, gestion des mots de passe, usage des équipements mobiles, télétravail, gestion des tiers.
3. **Procédures opérationnelles** : instructions détaillées d'application (gestion des incidents, sauvegardes).

Structure type d'une politique générale

- Objet et périmètre.
- Engagement de la direction.
- Organisation et responsabilités (rôles définis au chapitre 1).
- Principes directeurs (moindre privilège, défense en profondeur, séparation des tâches).
- Gestion des risques et conformité.
- Sanctions en cas de non-respect.
- Modalités de révision.

Une PSSI efficace est **connue, appliquée et révisée régulièrement** — une politique rédigée puis jamais diffusée ni actualisée est un signe classique d'immaturité relevé en audit organisationnel.

3. Plan de Continuité d'Activité (PCA) et Plan de Reprise d'Activité (PRA)

- **PCA** : ensemble des dispositions visant à assurer, en cas de crise majeure, le maintien (éventuellement dégradé) des activités essentielles de l'organisation.
- **PRA** : volet plus spécifiquement technique du PCA, centré sur la reprise des systèmes d'information après un sinistre.

Notions clés

Indicateur	Définition
RTO (Recovery Time Objective)	durée maximale d'interruption acceptable avant reprise du service
RPO (Recovery Point Objective)	perte de données maximale acceptable, exprimée en temps (ex. RPO de 4h = perte maximale des 4 dernières heures de données)

Ces deux indicateurs déterminent directement l'architecture de résilience à mettre en œuvre (fréquence de sauvegarde, site de secours actif/passif, réplication temps réel).

Étapes d'élaboration d'un PCA

1. Analyse d'impact sur l'activité (BIA — Business Impact Analysis) : identifier les processus critiques et leur RTO/RPO cible.
2. Définition des stratégies de continuité (site de secours, télétravail de crise, procédures dégradées).
3. Rédaction des plans opérationnels (qui fait quoi, avec quelles ressources).
4. Tests réguliers (exercices de crise, tests techniques de bascule).
5. Mise à jour continue.

Un PCA non testé est un PCA dont l'efficacité réelle est inconnue : les tests réguliers sont aussi importants que la rédaction du plan lui-même.

4. Gestion de crise cyber

Distincte mais complémentaire du PCA/PRA : une cellule de crise dédiée (souvent associant RSSI, DSI, communication, juridique, direction) doit pouvoir être activée rapidement en cas d'incident majeur (ex. rançongiciel), avec des procédures de décision pré-établies (isoler, communiquer, notifier les autorités compétentes le cas échéant).

À retenir

- Quatre stratégies de traitement du risque : éviter, réduire, transférer, accepter — le choix relève d'un arbitrage validé par la gouvernance.
- La PSSI se décline en plusieurs niveaux, de la politique générale aux procédures opérationnelles, et doit être vivante (diffusée, appliquée, révisée).
- RTO et RPO traduisent en exigences concrètes la criticité des processus métier et dimensionnent le PCA/PRA ; un plan non testé reste théorique.

Chapitre 4 — Pilotage, indicateurs et conformité réglementaire

Gouvernance et gestion des risques SI

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Pourquoi piloter par les indicateurs

Une gouvernance SSI mature ne se limite pas à produire des documents (PSSI, analyses de risque) : elle démontre, dans la durée, une amélioration mesurable. Les indicateurs permettent de communiquer objectivement avec la direction, de détecter une dérive avant qu'elle ne devienne un incident, et de justifier les investissements.

| 2. Caractéristiques d'un bon indicateur

Un indicateur utile est généralement décrit par les critères **SMART** : Spécifique, Mesurable, Atteignable, Réaliste, Temporellement défini. Il doit surtout être **actionnable** : un indicateur qui ne débouche sur aucune décision possible n'a pas d'intérêt opérationnel.

3. Exemples d'indicateurs SSI

Catégorie	Exemple d'indicateur
Vulnérabilités	délai moyen d'application des correctifs critiques (patch management)
Incidents	nombre d'incidents de sécurité déclarés par mois, temps moyen de détection (MTTD), temps moyen de résolution (MTTR)
Sensibilisation	taux de clics sur des campagnes de simulation de phishing
Conformité	pourcentage d'exigences ISO 27001 couvertes, nombre de non-conformités ouvertes
Continuité	résultat des derniers tests de PCA/PRA (RTO/RPO atteints ou non)
Accès	nombre de comptes à privilèges, délai de révocation des accès après départ d'un collaborateur

4. Tableau de bord SSI

Un tableau de bord synthétise ces indicateurs pour différents publics :

- **Vision direction** : quelques indicateurs agrégés, tendance (amélioration/dégradation), niveau de risque global.
- **Vision RSSI/opérationnelle** : indicateurs détaillés par domaine, permettant d'identifier les points d'action prioritaires.

La fréquence de mise à jour (mensuelle, trimestrielle) et le format (comité de pilotage, revue de direction) doivent être définis dans la gouvernance elle-même.

5. Conformité réglementaire : panorama non exhaustif

Cadre réglementaire	Portée	Point clé
RGPD (et lois nationales équivalentes de protection des données)	données à caractère personnel	notification des violations, analyse d'impact (AIPD) pour les traitements à risque
Réglementations sectorielles (banque, assurance, santé, télécoms)	secteurs régulés	exigences souvent renforcées (ex. résilience opérationnelle dans le secteur financier)
Réglementations nationales de cybersécurité (souvent inspirées de directives régionales)	opérateurs d'importance vitale ou essentiels	obligations de déclaration d'incident, exigences techniques minimales
Exigences contractuelles	relations clients/fournisseurs	souvent alignées sur ISO 27001 ou des questionnaires de sécurité spécifiques

La conformité n'est pas un objectif en soi mais un sous-ensemble de la gestion des risques : une organisation conforme n'est pas nécessairement sécurisée, et inversement une organisation bien sécurisée doit néanmoins documenter sa conformité pour ses obligations légales et contractuelles.

6. Revue de direction et amélioration continue

L'ISO 27001 impose une revue de direction périodique du SMSI, qui doit examiner : les résultats des audits internes/externes, l'état d'avancement du traitement des risques, les indicateurs de performance, les retours des parties intéressées, et déboucher sur des décisions (allocation de ressources, ajustement des priorités). C'est le point de bouclage du cycle PDCA introduit au chapitre 1.

| À retenir

- Un indicateur SSI doit être actionnable, pas seulement descriptif.
- Le tableau de bord se décline selon le public (direction vs opérationnel) pour rester pertinent à chaque niveau.
- La conformité réglementaire est une composante de la gestion des risques, pas un objectif indépendant ; elle se pilote au même titre que les autres indicateurs.